

Security Report

Layman Terms

Security Report: What We Found & What It Means

Target Systems: localhost and schedrok

Date: 27 February 2026

What Is This Document?

This report explains, in plain English, what our security scan found on two systems. No technical jargon. Think of it like a home inspection report — we checked the locks, the windows, and the foundations, and we found a few problems that need fixing.

The Two Systems We Checked

System	What It Is
localhost	The local server running on this machine
schedrok	A separate server running a web application

What We Found — Simple Version

On localhost — 2 issues

Issue 1 — Unlocked Filing Cabinet

Severity: Medium (Should Be Fixed Soon)

Imagine leaving a filing cabinet unlocked in the office hallway with a sign on it saying “backup files inside.” Anyone walking past can open it and take what’s inside.

That is exactly what is happening at the /backup folder on localhost. It is publicly accessible and contains database files and configuration files that should be private.

The risk: Someone could download your database backup or find passwords stored in the config files.

The fix: Lock the door. Tell the web server not to show the contents of that folder.

Issue 2 — Nameplate on the Front Door

Severity: Low (Fix When Convenient)

The server is advertising exactly what software it is running and which version, like wearing a name badge that says “I am running Apache 2.4.52.”

This alone is not dangerous, but it helps an attacker know exactly which known weaknesses to try against the system.

The fix: Configure the server to stop announcing its version number.

On schedrok — 3 issues

Issue 3 — Broken Front Door Lock (CRITICAL — Fix Immediately)

Severity: Critical — Urgent Action Required

CVE-2021-44228 — Known as “Log4Shell”

This is one of the most serious software vulnerabilities discovered in recent years. It affects a very common piece of software that many applications use behind the scenes to keep logs (like a diary of activity).

In plain terms: an attacker can send a specially crafted message to the server — something as simple as a line in a web request — and the server will automatically run whatever code the attacker

tells it to. It is like slipping a note under the door that says “call this number” and the building automatically does it, no questions asked.

What an attacker can do if this is not fixed: - Take full control of the schedrok server - Read all files on the system, including passwords and private data - Use the server as a base to attack other systems on the same network - Install malware or ransomware

The fix: 1. Update the Log4j2 software to version 2.17.1 or newer — today 2. While waiting for the update, add a setting that disables the dangerous feature 3. Block the server from making outgoing connections it does not need

Issue 4 — Magic Link Attack

Severity: High (Fix This Week)

The search page on schedrok (/search) takes whatever you type and displays it back on the screen without checking it first.

An attacker can craft a special link, trick someone (like an admin) into clicking it, and their browser will run the attacker’s code silently. This is called Cross-Site Scripting (XSS).

What an attacker can do: - Steal login session cookies — effectively logging in as that person - Redirect users to a fake login page to harvest credentials - Silently perform actions on the site as the victim

The fix: The search page must check and clean all input before displaying it.

Issue 5 — Nameplate on the Front Door

Severity: Low (Fix When Convenient)

Same as localhost — the server advertises its software versions publicly. nginx 1.18.0 and Jetty 9.4.x are both visible to anyone who looks.

The fix: Suppress version information in server responses.

Priority Order — What to Fix First

Priority	Issue	System	How Urgent
1	Log4Shell RCE	schedrok	Fix today — attacker gets full control
2	Magic Link (XSS)	schedrok	Fix this week
3	Unlocked / backup folder	localhost	Fix this week
4	Version disclosure	localhost + schedrok	Fix when convenient

What Happens If Nothing Is Fixed?

Log4Shell (Issue 3) is the most dangerous finding. If left unpatched:

1. An attacker finds the server (takes minutes with public scanning tools)
2. They send one specially crafted request
3. They have full remote access to the server
4. They can move from schedrok to other systems on the same network
5. Data theft, ransomware, or complete system takeover becomes possible

Glossary — Plain English Definitions

Term	What It Means
RCE	Remote Code Execution — an attacker can run any program on your server from anywhere in the world
XSS	Cross-Site Scripting — an attacker injects code into your website that runs in other users' browsers
CVE	Common Vulnerabilities and Exposures — a public database of known software weaknesses
JNDI	

Term	What It Means
	A Java feature that Log4Shell abuses to make the server fetch and run remote code
Severity: Critical	Drop everything and fix this now
Severity: High	Fix within days
Severity: Medium	Fix within weeks
Severity: Low	Fix in the next maintenance window

Report generated by HexStrike AI — for internal use only